

This class has taught me many things about software security. One of which is that software security isn't simply adding credentials or a login page to secure the app. It happens at every stage of development. We created and researched coding standards in this class, and I was a little surprised that the security standards seemed to be more about using best practices in code rather than locking down a database or something else. If there are cracks and holes in the code, it gives a doorway for hackers to access your application. It is important that our code is simple and to the point so that it efficiently and cleanly accomplishes the task. Adopting a coding standard is a great way to accomplish this. It gives specific, actionable ideas that developers can use in their code to really make a difference to the company's security. It shouldn't be left to the end but thought about throughout the entire process, just like the DevSecOps lifecycle.

The amount of measures taken by a company can often reflect their evaluation and assessment of the risk and cost from potential security concerns. Ray Dunham, a software security professional with an incredible career and track record, says that "information security policies reflect the risk appetite of an organization's management and should reflect the managerial mindset when it comes to security" (Dunham, 2020). This paints the picture that the security policies and risk assessment that companies conduct isn't necessarily set in stone. They are ideas and opinions of how certain risks could affect their company. This allows them to prioritize certain points and include key policies in their lifecycle for developers to focus on.

I also really enjoyed learning about the "zero trust" policy. It is essentially saying that "organizations should not automatically trust anything inside and outside their network perimeters" (Fortra, 2024). This makes it so that if an intruder makes it into the internal network, they will not have access to everything. Any user that uses the system must be verified at every step. It really minimizes the risk of losing data and getting hurt during a breach. This is

especially important nowadays for companies where they have many remote workers connecting from different networks.

Lastly, when you actually implement these policies, I would like to say it is never too late. You can determine what your system may be missing and add it later. However, I do lean more towards the DevSecOps pipeline now. This allows us to have developers creating tests, writing secure code, and taking the proper steps from the beginning to ensure we stay secure. It is a lot harder to go through all the code a second time and see what we need to add. Especially enterprise level applications. They can be so complex that there are thousands and thousands of lines of code. I believe implementing and recommending security policies to organizations is best at the beginning of the process.

References

- Dunham, R. (2020, May 5). *Information Security Policies: Why They Are Important to Your Organization*. Linford & Company LLP. <https://linfordco.com/blog/information-security-policies/>
- Fortra. (2024, October 23). *Understanding the Zero Trust Security Model to Safeguard Digital Infrastructure* | Fortra. Fortra.com. <https://www.fortra.com/blog/understanding-zero-trust-security-model-safeguard-digital-infrastructure>